

HTTP 体系，用于安全的 HTTP 数据传输。HTTPS 实际上应用了 SSL 作为 HTTP 应用层的子层，HTTPS 使用端口 443（也可以指定其他 TCP 端口），而不是像 HTTP 那样使用端口 80 来和 TCP/IP 进行通信。HTTPS 和 SSL 支持使用 X.509 数字认证，如果需要的话，用户可以确认发送者是谁。也就是说，它的主要作用有两个：一个是建立一个信息安全通道，来保证数据传输的安全；另一个就是确认网站的真实性。

3. PGP

PGP 是一个基于 RSA 的邮件加密软件，可以用它对邮件保密以防止非授权者阅读，它还能对邮件加上数字签名，从而使收信人可以确信邮件发送者。PGP 的基本原理是，先用对称密钥加密传送的信息，再将该对称加密密钥以接收方的公钥加密，组成数字信封，并将此密钥交给公正的第三方保管；然后，将此数字信封传送给接收方。接收方必须先以自己的私钥将数字信封拆封，以获得对称解密密钥，再以该对称解密密钥解出真正的信息，兼顾了方便与效率。

PGP 还可用于文件存储的加密。PGP 承认两种不同的证书格式，分别是 PGP 证书和 X.509 证书。其中，一份 PGP 证书包括版本号、证书持有者的公钥、证书持有者的信息（例如，姓名、用户 ID、照片等）、证书拥有者的数字签名、证书的有效期和密钥首选的对称加密算法等内容。

4. IPSec

IPSec 是一个工业标准网络安全协议，为 IP 网络通信提供透明的安全服务，保护 TCP/IP 通信免遭窃听和篡改，可以有效抵御网络攻击，同时保持易用性。IPSec 有两个基本目标，分别是保护 IP 数据包安全和为抵御网络攻击提供防护措施。IPSec 结合密码保护服务、安全协议组和动态密钥管理三者来实现上述两个目标。

IPSec 是针对 IPv4 和 IPv6 的，其主要特征是可以支持 IP 级所有流量的加密和 / 或认证，增强所有分布式应用的安全性。IPSec 在 IP 层提供安全服务，使得系统可以选择所需要的安全协议，确定该服务所用的算法，并提供安全服务所需任何加密密钥。

IPSec 是一种基于端对端的安全模式。这种模式有一个基本前提假设，就是假定数据通信的传输媒介是不安全的。因此，通信数据必须经过加密，而掌握加解密方法的只有数据的发送端和接收端，两者各自负责相应的数据加解密处理，网络中其他只负责转发数据的路由器或计算机无须支持 IPSec。

9.3.4 单点登录技术

随着信息化的迅猛发展，用户每天需要登录到许多不同的信息系统，例如，邮件、数据库和各种应用服务器等。每个系统都要求用户遵循一定的安全策略，例如，要求输入用户名和口令等。随着用户需要登录系统的增多，出错的可能性就会增加，受到非法截获和破坏的可能性也会增大，安全性就会相应降低。而一旦用户忘记了口令，就不能执行任务，就需要请求管理员的帮助，在重新获得口令之前只能等待，造成系统和安全管理资源的开销，降低了生产效率。特别是新系统的涌现，在与现有系统的集成或融合上，尤其是针对相同的用户群，会带来以下问题：

（1）如果每个系统都开发各自的身份认证系统，则将造成资源浪费，消耗开发成本，并延缓开发进度。

(2) 多个身份认证系统会增加整个系统的管理工作成本。

(3) 用户需要记忆多个账号和口令，使用极为不便。同时，由于用户口令遗忘而导致的支持费用不断上涨。

(4) 无法实现统一的认证和授权，多个身份认证系统使安全策略必须逐个在不同的系统内进行设置，因而造成修改策略的进度可能跟不上策略的变化；无法统一分析用户的应用行为。

因此，对于有多个业务系统应用需求的组织，需要配置一套统一的身份认证系统，以实现集中、统一的身份认证，并减少整个系统的成本。

1. 单点登录系统的概念

单点登录（Single Sign-On, SSO）技术是通过用户的一次性认证登录，即可获得需要访问系统和应用程序的授权，在此条件下，管理员不需要修改或干涉用户登录，就能方便地实现希望得到的安全控制。

单点登录系统采用基于数字证书的加密和数字签名技术，基于统一策略的用户身份认证和授权控制功能，对用户实行集中、统一的管理和身份认证，以区别不同的用户和信息访问者，并作为各应用系统的统一登录入口，同时，为通过身份认证的合法用户签发针对各个应用系统的登录票据（ticket），从而实现“一点登录，多点漫游”。必要时，单点登录系统能够与统一权限管理系统实现无缝结合，签发合法用户的权限票据，从而能够使合法用户进入其权限范围内的各应用系统，并完成符合其权限的操作。

2. SSO 系统的特征与功能

单点登录的实施可由 Kerberos 机制和外壳脚本机制来实现，也可以采用通用的安全服务 API 和分布式计算环境。一个理想的 SSO 产品应该具备以下特征和功能：

(1) 常规特征。支持多种系统、设备和接口。

(2) 终端用户管理灵活性。包括通常的账号创建、口令管理和用户识别。口令管理包括口令维护、历史记录和文法规则等；支持各种类型的令牌设备和生物学设备。

(3) 应用管理灵活性。若多个会话同时与一个公共主体相关，设备场景管理能保证其中一个会话发生改变，其他相关会话自动更新；能监控特定信息的使用；可将各种应用绑定在一起，来保证应用的一致性。

(4) 移动用户管理。保证用户在不同的地点对信息资源进行访问。

(5) 加密和认证。加密保证信息在终端用户和安全服务器之间传输时的安全性；认证保证用户的真实性。

(6) 访问控制。保证只有用户被授权访问的应用可以提供给用户。

(7) 可靠性和性能。包括 SSO 和其他访问控制程序之间的接口的可靠性和性能，以及接口的复杂度等。

3. Kerberos 机制

Kerberos 是一种网络身份认证协议，该协议的基础是基于信任第三方，它提供了在开放型网络中进行身份认证的方法，认证实体可以是用户也可以是用户服务。这种认证不依赖宿主机